

Alexander Ticket

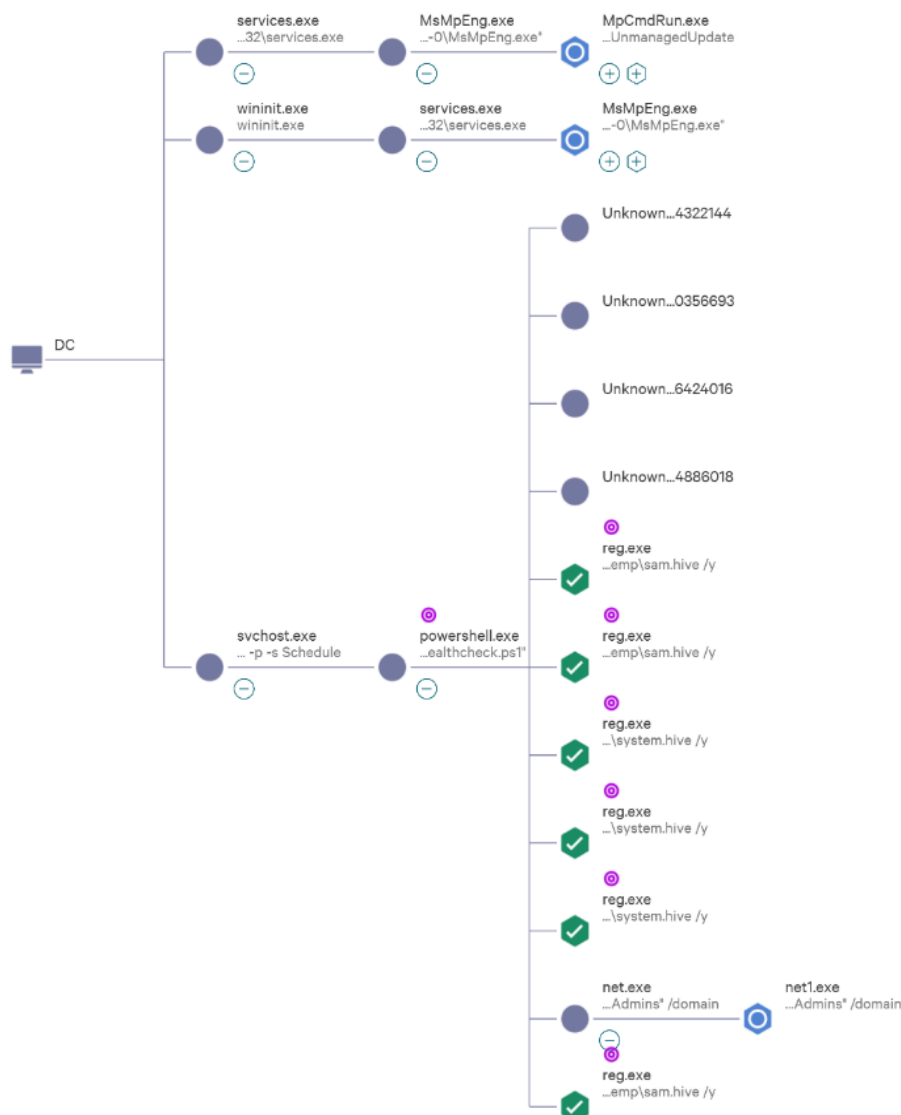
Note: This report has been sanitized for public sharing.

All internal IPs, hostnames, and CrowdStrike URLs have been redacted or replaced with simulated values.

Report was originally prepared for Jira; internal console links are not publicly accessible. Query references shown for context

The Summary :

The alert indicates a sequence of debugger evasion, high-severity OS credential dumping via SAM/SYSTEM hive exports, and Active Directory discovery targeting privileged domain groups on host DC



CrowdStrike Link:

- **Incident(CrowdScore):**

(internal link, redacted for confidentiality)

- **Endpoint Detection:**

(internal link, redacted for confidentiality)

- **Associated Lead (Discovery):**

(internal link, redacted for confidentiality)

Description

A multi-stage intrusion was detected on host [redacted-host], characterized by targeted efforts to dump domain credentials and perform Active Directory reconnaissance. The activity involved the abuse of legitimate system binaries and native Windows Defender processes to evade detection and prepare for a full domain compromise.

The incident began with suspicious activity from **MpCmdRun.exe** and **MsMpEng.exe**, which were flagged for **Defense Evasion (T1622)** via debugger checks and obtaining a handle to the **LSASS** process. These maneuvers are typical of an adversary attempting to analyze the environment for security tools while simultaneously preparing for **OS Credential Dumping**.

Subsequently, a manual attempt to extract sensitive registry hives was observed. An adversary utilized **reg.exe** to export the **SAM** and **SYSTEM** hives to a temporary directory (**C:\Windows\Temp**). These hives contain the local password hashes and the boot key required for offline decryption. Advanced telemetry confirmed that the Falcon sensor successfully **blocked** these execution attempts (**Credential Access via OS Credential Dumping**), preventing the completion of the theft.

Despite the blocked credential dumping, the adversary successfully performed **Active Directory Discovery** using **net1.exe**. Specifically, the command **net1 group "Domain Admins" /domain** was executed to identify users with elevated privileges. The combination of targeted credential theft attempts on a Domain Controller and active reconnaissance of privileged groups indicates a high-priority threat aimed at achieving **Privilege Escalation** and maintaining long-term control over the domain infrastructure.

◆ **Host Information:**

Hostname: [redacted-host]
Operating System: Windows Server 2019
IP Address: [redacted]
Local IP Address: [redacted internal IP]
Host Type: Domain Controller

◆ **User Information:**

1. Targeted System Account::

Username: DC\$
Local Admin: No
Role: LocalSystem account leveraged for high-privilege operations, including LSASS handle acquisition and registry hive exports.

Login Time: Feb. 19, 2025 12:49:31

Login Domain: [redacted-domain]

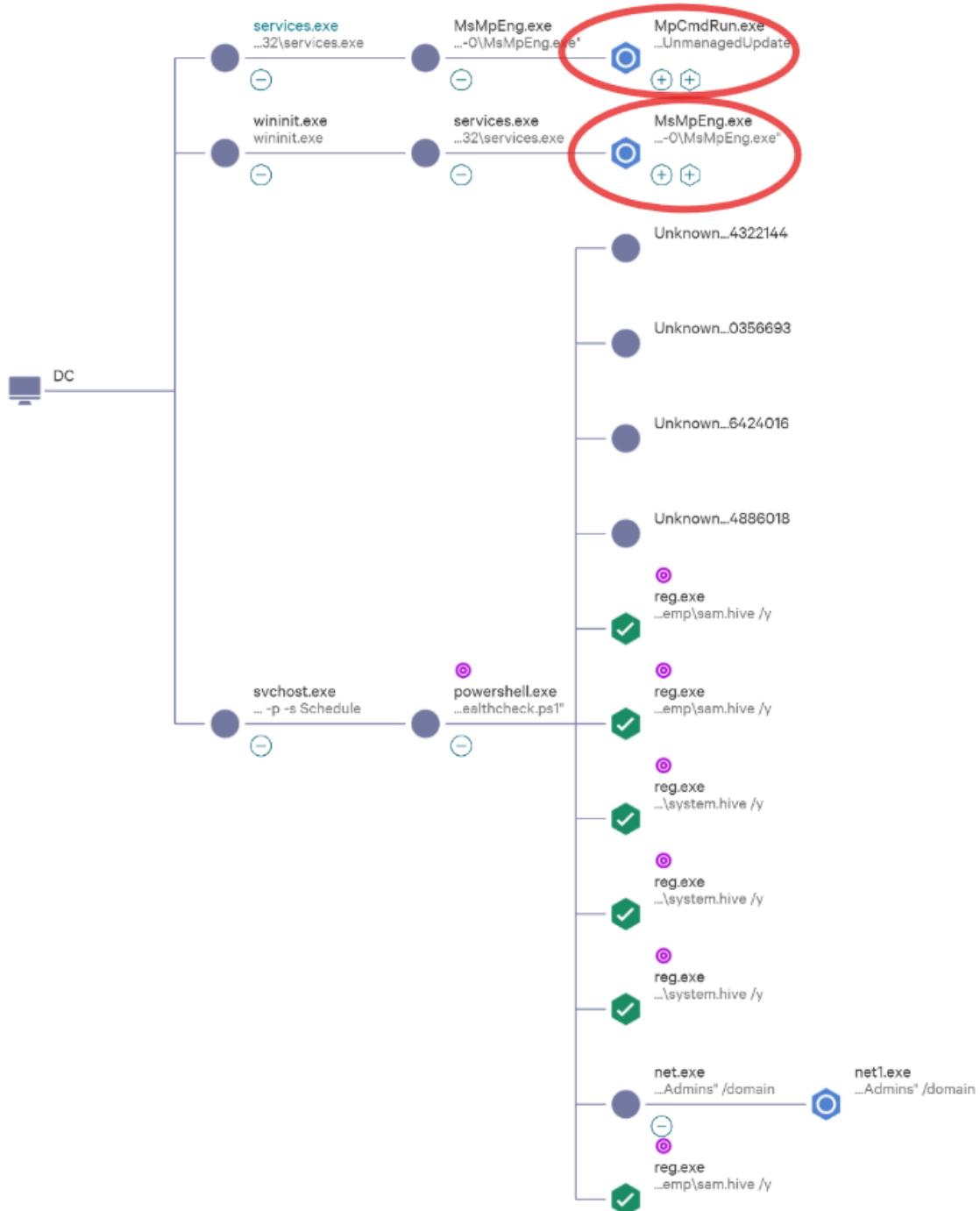
◆ **Tactic & Technique:**

Credential Access via OS Credential Dumping (SAM/SYSTEM hives), Discovery via Domain Groups, Defense Evasion via Debugger Evasion, Persistence via Registry Run Keys / Startup Folder, AI Powered IOA via User Execution.

MITRE ATT&CK ID: T1003.002, T1069.002, T1622, T1547.001, T1204.002

Investigation Findings and Analysis:

Observed Command 1:



① Phase 1 : Defense Evasion & Security Impairment

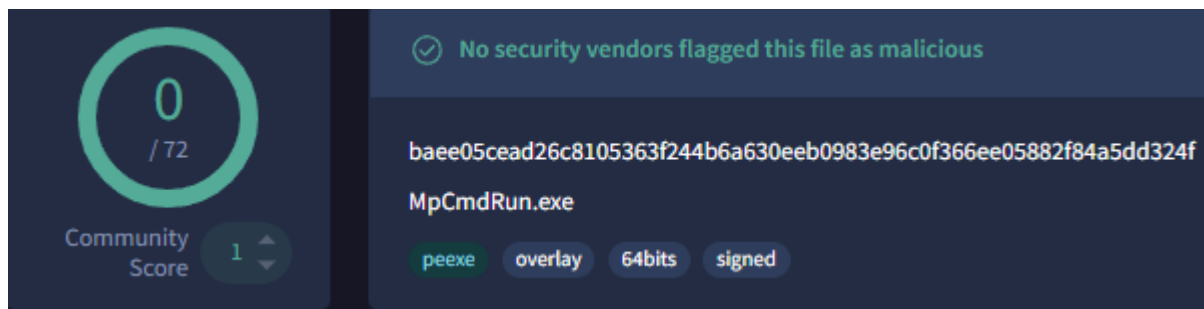
Process: MpCmdRun.exe

Start time: Feb. 18, 2025 16:54:23

Executable SHA256

baee05cead26c8105363f244b6a630eeb0983e96c0f366ee05882f84a5dd324f

[Result there]<https://www.virustotal.com/gui/file/baee05cead26c8105363f244b6a630eeb0983e96c0f366ee05882f84a5dd324f/detection>]



The process tree shows the execution of **MpCmdRun.exe**, a legitimate Microsoft Defender command-line utility. While the command line arguments (**SignaturesUpdateService**) appear to mimic routine signature updates, the EDR flagged this activity as **Debugger Evasion**.



Identified by CrowdStrike as an automated lead:

Detection: Defense Evasion via Debugger Evasion

Detection Timestamp: Feb. 19, 2025 11:52:10

Command line

```
"C:\ProgramData\Microsoft\Windows  
Defender\Platform\4.18.25010.11-0\MpCmdRun.exe"  
SignaturesUpdateService -ScheduleJob -UnmanagedUpdate
```

File path

```
\Device\HarddiskVolume2\ProgramData\Microsoft\Windows  
Defender\Platform\4.18.25010.11-0\MpCmdRun.exe
```

This suggests that the process—or code injected into it—was actively attempting to detect the presence of security analysis tools or debuggers. In a post-compromise environment, adversaries frequently leverage **Living-off-the-Land** techniques by using trusted security binaries to perform reconnaissance or to "blind" the defensive suite. The objective here was **Defense Evasion**, ensuring that subsequent malicious phases, such as the credential dumping observed later, would not be interrupted by automated security responses.

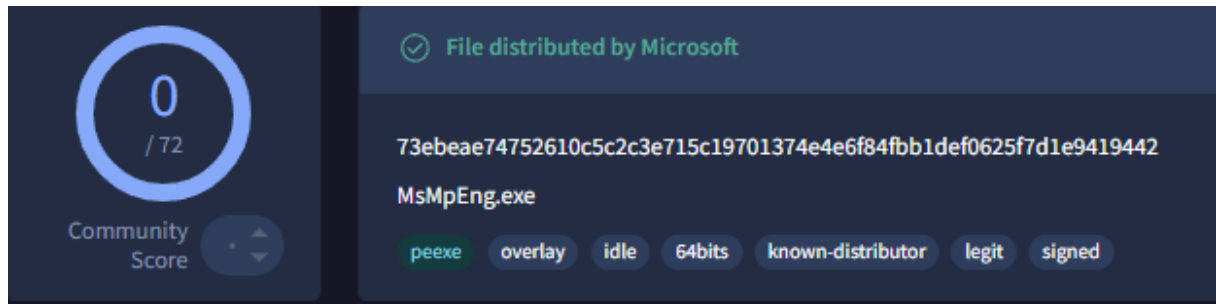
Process: MsMpEng.exe

Start time: Feb. 19, 2025 11:51:46

Executable SHA256

73ebeae74752610c5c2c3e715c19701374e4e6f84fbb1def0625f7d1e9419442

[Result there]<https://www.virustotal.com/gui/file/73ebeae74752610c5c2c3e715c19701374e4e6f84fbb1def0625f7d1e9419442>]



The EDR detected a critical behavioral anomaly where a remote process (likely controlled by the adversary) obtained a handle to the **LSASS (Local Security Authority Subsystem Service)** via the legitimate **MsMpEng.exe** process. LSASS is the primary target for **Credential Access**, as it stores active user credentials and tokens in memory.



Identified by CrowdStrike as an automated lead:

Detection: Credential Access via OS Credential Dumping

Detection Timestamp: Feb. 19, 2025 11:52:10

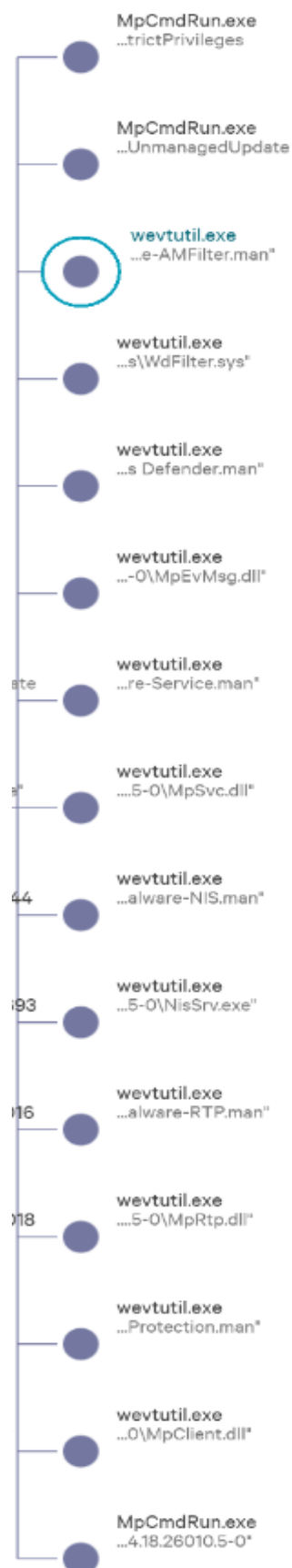
Command line

"C:\ProgramData\Microsoft\Windows Defender\Platform\4.18.25010.11-0\MsMpEng.exe"

File path

\Device\HarddiskVolume2\ProgramData\Microsoft\Windows Defender\Platform\4.18.25010.11-0\MsMpEng.exe

By leveraging the Antimalware Service (**MsMpEng.exe**) to access LSASS memory, the attacker is employing an advanced **Living-off-the-Land (LotL)** technique. This is intended to deceive security monitors, as access to system memory by a security service is often considered "normal" or is less scrutinized by standard detection rules.



The process tree reveals an extensive series of **wevtutil.exe** commands executed as children of Defender:

wevtutil.exe uninstall-manifest / install-manifest → The adversary targeted multiple Windows Defender components, including:

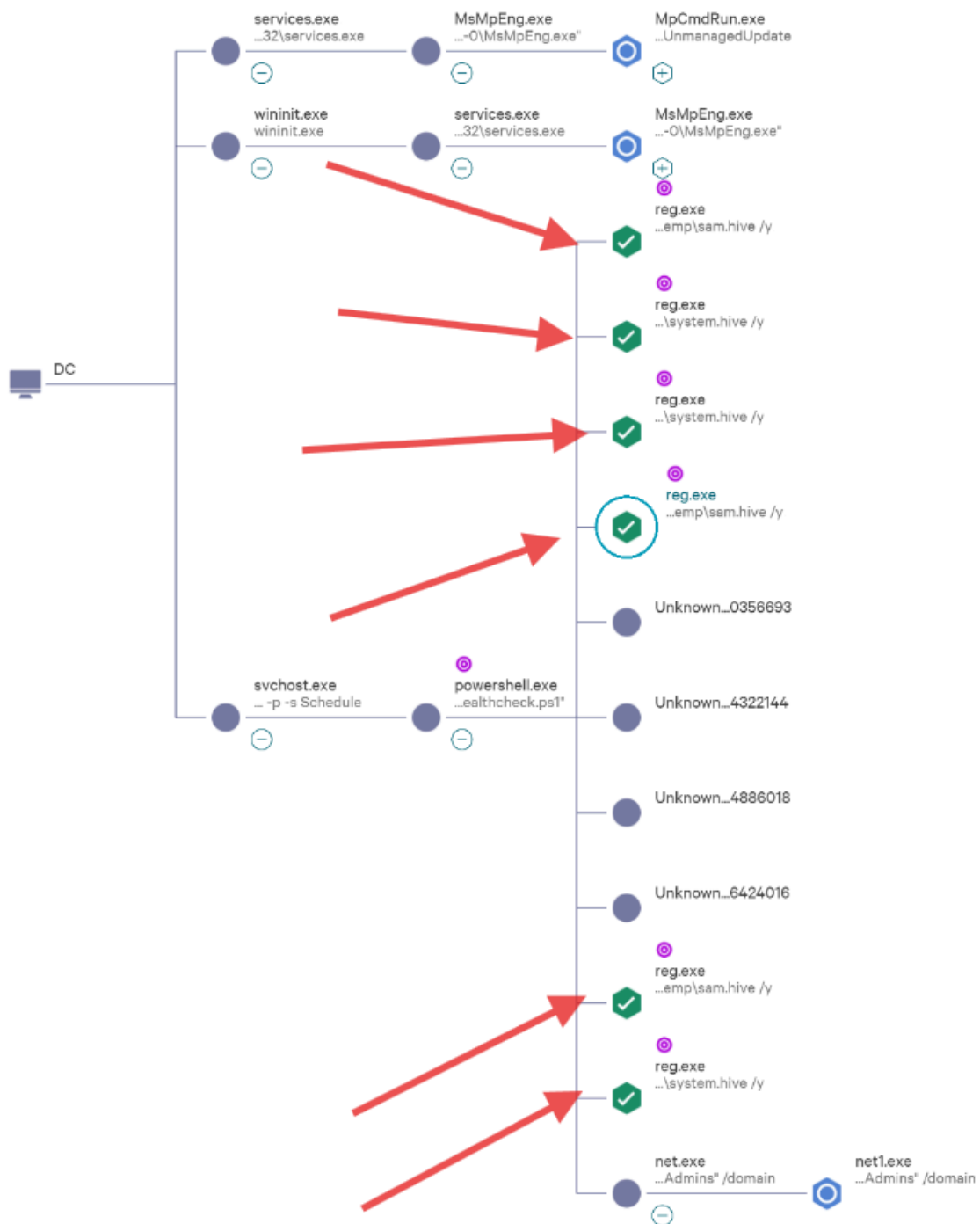
AMFilter (Antimalware Filter)

RTP (Real-Time Protection)

NIS (Network Inspection Service)

Purpose: Manipulating event manifests via **wevtutil** is a sophisticated form of **Indicator Removal**. By uninstalling and reinstalling these manifests, the attacker can effectively "mute" specific security event logs or reset the logging configuration to hide their footprints during the active breach.

Observed Command 2:



② Phase 2 : Scripted Execution & Credential Access Attempt

Process: powershell.exe

Start time(UTC): Feb. 19, 2025 12:49:35

End time(UTC): Feb. 19, 2025 12:50:19

Command line

```
"powershell.exe" -WindowStyle Hidden -ExecutionPolicy Bypass  
-NonInteractive -File "C:\Windows\Temp\healthcheck.ps1"
```

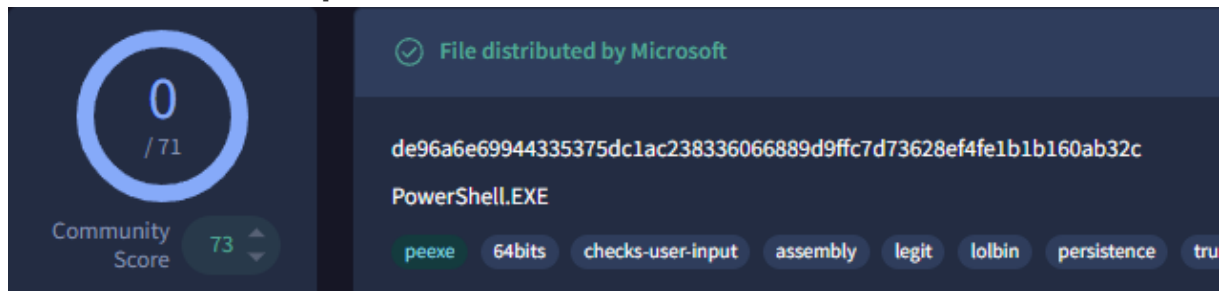
File path

```
\Device\HarddiskVolume2\Windows\System32\WindowsPowerShell\v1.  
0\powershell.exe
```

Executable SHA256

```
de96a6e69944335375dc1ac238336066889d9ffc7d73628ef4fe1b1b160ab3  
2c
```

[Result there]<https://www.virustotal.com/gui/file/de96a6e69944335375dc1ac238336066889d9ffc7d73628ef4fe1b1b160ab32c>]



Parent Process: **svchost.exe** (`svchost.exe -k netsvcs -p -s Schedule`)

Phase 2 initiated via a **Scheduled Task**, indicated by the parent **svchost.exe** process. The adversary utilized a PowerShell script masquerading as a system utility (**healthcheck.ps1**) located in the world-writable **C:\Windows\Temp** directory.

The command-line arguments reveal a deliberate attempt at **Defense Evasion**:

WindowStyle Hidden: To hide the console from any interactive user.

ExecutionPolicy Bypass: To ignore the system's script-signing requirements.

NonInteractive: To ensure the script runs to completion without prompting for input.

Disk Operations & Technical Indicators: During execution, the EDR observed the creation of a temporary policy test script (**__PSScriptPolicyTest_felvshgb.qqj.ps1**). This is a standard PowerShell behavior when checking execution constraints. More importantly, the script acted as a **dropper/launcher**, immediately spawning a series of **reg.exe** processes to perform credential theft.

🟢 Targeted Registry Hive Export (Blocked)

Processes: **reg.exe** (Multiple instances observed in rapid succession)

Start time(UTC): Feb. 19, 2025 12:50:12

End time(UTC): Feb. 19, 2025 12:50:14

Actions taken: **Process blocked** (PatternDisposition: 2048)

Risk score: 57 **Severity:** 90 (Critical)

```
RiskScore: 57
Severity: 90
SeverityName: Critical
```

Command Lines Observed:

Command line

```
"C:\Windows\system32\reg.exe" save HKLM\SAM
C:\Windows\Temp\sam.hive /y
```

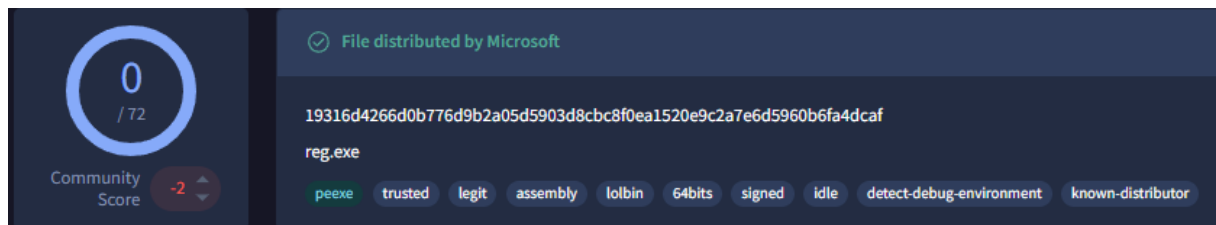
Command line

```
"C:\Windows\system32\reg.exe" save HKLM\SYSTEM
C:\Windows\Temp\system.hive /y
```

Executable SHA256:

19316d4266d0b776d9b2a05d5903d8cbc8f0ea1520e9c2a7e6d5960b6fa4dc
af

[Result here]<https://www.virustotal.com/gui/file/19316d4266d0b776d9b2a05d5903d8cbc8f0ea1520e9c2a7e6d5960b6fa4dc4dcaf/detection>]



VirusTotal **Execution Parents** analysis reveals that this specific binary is frequently leveraged by malicious payloads (3/5 malicious parent ratio). This aligns with the observed **Living-off-the-Land (LotL)** strategy, where the adversary utilizes trusted system tools to perform unauthorized registry exports (**HKLM\SAM**).

The adversary utilized the native Windows Registry utility to attempt **OS Credential Dumping**. The goal was to extract the **SAM** (Security Account Manager) hive for local NTLM hashes and the **SYSTEM** hive to obtain the boot key required for decryption.

Technical validation via **Advanced Event Search (AES)** confirms that the Falcon sensor successfully intervened. All identified **reg.exe** instances returned a **PatternDisposition: 2048 (Blocked)**. The sensor recognized the unauthorized access to sensitive registry hives and terminated the execution chain before any sensitive data could be written to the **C:\Windows\Temp** directory. The rapid-fire execution of these commands (as seen in the 2-second window) indicates an automated loop within the **healthcheck.ps1** script, designed to force the export despite security controls.

```
"PatternDisposition": "2048"
```

Raw telemetry from **Advanced Event Search (AES)** identifies the external agent IP (aip) as **[redacted]** during the execution of the malicious PowerShell and **reg.exe** chain. Cross-referencing this with the host's IP history confirms this was the active public-facing address of the Domain Controller at the time of the compromise.

(internal link, redacted for confidentiality)

(internal link, redacted for confidentiality)

Rawstring 1:

```
@rawstring:{"ComputerName":"DC","ConfigBuild":"1007.3.0020505.15","ConfigStateHash":"3181781004","ContextTimeStamp":"1739969414.599","EffectiveTransmissionClass":"2","Entitlements":"15","EventCorrelationId":"04f0bf4d-bb0d-f111-b17c-bc24115a9000","EventOrigin":"1","GrandparentProcessBehavioralContext":"","LocalAddressIP4":"[redacted]","ParentProcessBehavioralContext":"","PatternDisposition":"2048","PatternId":"10117","ProcessBehavioralContext":"","TargetProcessId":"124693031207","TemplateId":"1","TemplateInstanceId":"8864","TreeId":"124558724523","TreeRoot":"124693031207","aid":"9b806ac4866a491bb8b1832f865c5545","aip":"[redacted]","cid":"55ff35c57f0441f19baad0a47c239f7d","event_platform":"Win","event_simpleName":"AssociateTreeIdWithRoot","id":"a8cb7582-981a-45cb-8202-d74c1df5a685","name":"AssociateTreeIdWithRootV13","timestamp":"1739970214503"}
```

Rawstring 2:

```
@rawstring:{"ProcessStartTime":1739969414,"ProcessEndTime":1739969414,"ProcessId":124693842571,"ParentProcessId":124603872216,"Hostname":"DC","UserName":"DC$","Name":"Credential Theft","Description":"A process saved the Security Account Manager SAM or SYSTEM hive to disk. If this is unexpected, it likely indicates credential theft. Investigate the process tree.","Severity":90,"SeverityName":"Critical","FileName":"reg.exe","FilePath":"\\Device\\HarddiskVolume2\\Windows\\System32\\reg.exe","CommandLine":"\\C:\\Windows\\system32\\reg.exe\" save HKLM\\SYSTEM C:\\Windows\\Temp\\system.hive /y","SHA256String":"19316d4266d0b776d9b2a05d5903d8cbc8f0ea1520e9c2a7e6d5960b6fa4dcac","MD5String":"8a93acac33151793f8d52000071c0b06","SHA1String":"00000000000000000000000000000000","LogonDomain":"[redacted]","FalconHostLink":"[redacted]","AgentId":"9b806ac4866a491bb8b1832f865c5545","IOCType":"hash_sha256","IOCValue":"19316d4266d0b776d9b2a05d5903d8cbc8f0ea1520e9c2a7e6d5960b6fa4dcac","CompositeId":"55ff35c57f0441f19baad0a47c239f7d:ind:9b806ac4866a491bb8b1832f865c5545:124693842571-10117-360976","LocalIP":"[redacted]","MACAddress":"bc-24-11-5a-90-00","Tactic":"Credential Access","Technique":"OS Credential Dumping","Objective":"Gain Access","PatternDispositionDescription":"Prevention, process was blocked from execution.","PatternDispositionValue":2048,"PatternDispositionFlags":{"Indicator":false,"Detect":false,"InddetMask":false,"SensorOnly":false,"Rooting":false,"KillProcess":false,"KillSubProcess":false,"QuarantineMachine":false,"QuarantineFile":false,"PolicyDisabled":false,"KillParent":false,"OperationBlocked":false,"ProcessBlocked":true,"RegistryOperationBlocked":false,"CriticalProcessDisabled":false,"BootupSafeguardEnabled":false,"FsOperationBlocked":false,"HandleOperationDowngraded":false,"KillActionFailed":false,"BlockingUnsupportedOrDisabled":false,"SuspendProcess":false,"SuspendParent":false,"ContainmentFileSystem":false},"ParentImageFileName":"powershell.exe","ParentCommandLine":"\\powershell.exe\" -WindowStyle Hidden -ExecutionPolicy Bypass -NonInteractive -File \\C:\\Windows\\Temp\\healthcheck.ps1","GrandParentImageFileName":"svchost.exe","GrandParentCommandLine":"C:\\Windows\\system32\\svchost.exe -k netsvcs -p -s Schedule","HostGroups":"c6cffe1d95944fe48f105a75c4bf4ec6","AssociatedFile":"\\Device\\HarddiskVolume2\\Windows\\System32\\reg.exe","PatternId":10117,"SourceVendors":{"CrowdStrike","SourceProducts":"Falcon Insight","DataDomains":{"Endpoint","AggregateId":"aggind:9b806ac4866a491bb8b1832f865c5545:124560003564","Type":"ldt","ParentImagePath":"\\Device\\HarddiskVolume2\\Windows\\System32\\WindowsPowerShell\\v1.0\\powershell.exe","GrandParentImagePath":"\\Device\\HarddiskVolume2\\Windows\\System32\\svchost.exe","LocalIPv6":"","PlatformId":"0","PlatformName":"Windows","MitreAttack":[{"Tactic":"Credential Access","TacticID":"TA0006","Technique":"OS Credential Dumping","TechniqueID":"T1003","PatternID":10117}],"CloudIndicator":false,"RiskScore":57,"CustomerIdString":"55ff35c57f0441f19baad0a47c239f7d","UTCTimestamp":1739970329,"Nonce":4547031238247566752,"AgentIdString":"9b806ac4866a491bb8b1832f865c5545","cid":"55ff35c57f0441f19baad0a47c239f7d","eid":118,"timestamp":"2025-02-19T13:05:29Z","EventType":"Event_ExternalApiEvent","ExternalApiType":"Event_EppDetectionSummaryEvent"}}
```

A clear attempt at **OS Credential Dumping**. The adversary tried to exfiltrate the **SYSTEM** hive to obtain boot keys for offline password decryption.

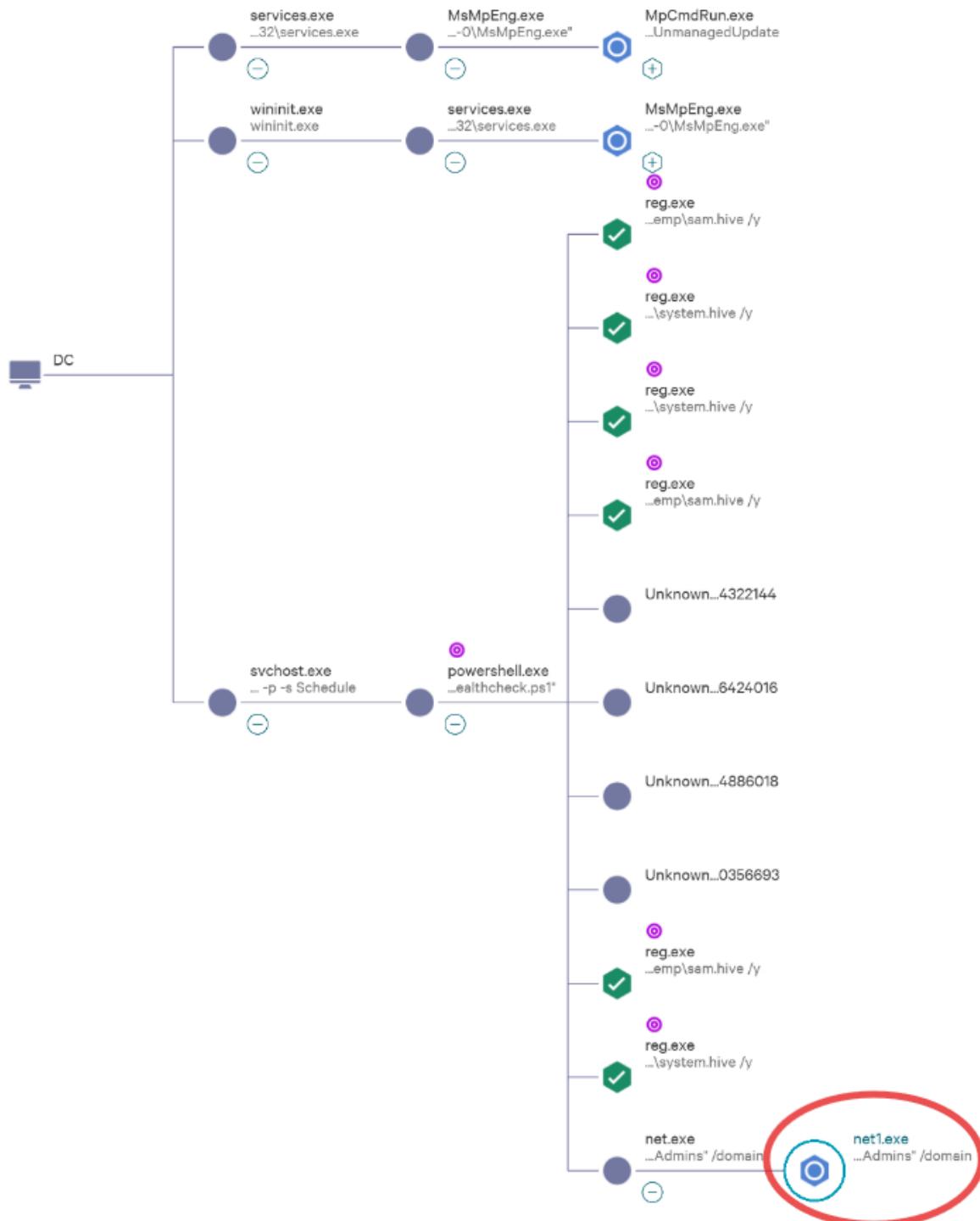
A multi-stage execution chain starting from a **Scheduled Task** (**svchost.exe**) which launched a hidden PowerShell script (**healthcheck.ps1**) to trigger **reg.exe**.

The Verdict: SUCCESSFUL BLOCK.

- **PatternDispositionValue:** 2048
- **ProcessBlocked:** true
- The EDR terminated the process at the kernel level before any sensitive data was written to disk.

Activity was associated with external IP [redacted], which should be the primary focus for firewall/VPN log correlation.

Observed Command 3:



③ Phase 3: Active Directory Discovery & Reconnaissance

Process: net1.exe

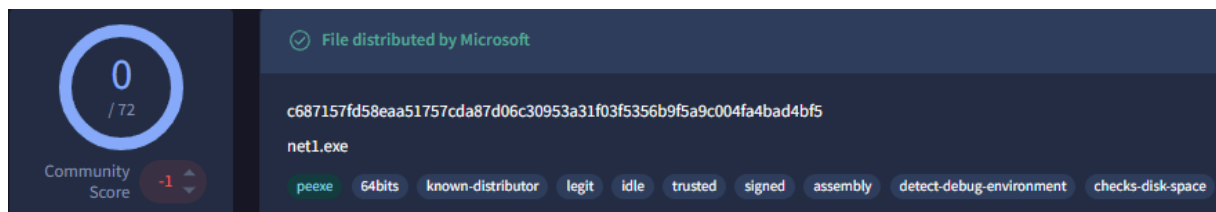
Start time(UTC): Feb. 19, 2025 12:50:17

End time(UTC): Feb. 19, 2025 12:50:17

Executable SHA256

c687157fd58eaa51757cda87d06c30953a31f03f5356b9f5a9c004fa4bad4bf5

[Result there]<https://www.virustotal.com/gui/file/c687157fd58eaa51757cda87d06c30953a31f03f5356b9f5a9c004fa4bad4bf5/detection>]



While the **net1.exe** binary is a verified system component, VirusTotal analysis reveals it has **3 malicious Execution Parents**. This indicates that the binary is a known tool utilized by various malware families for **Active Directory Reconnaissance**. Furthermore, associated network telemetry shows a connection to a suspicious domain (1/94 detections), aligning with a **Command & Control (C2)** operational pattern.

Identified by CrowdStrike as an automated lead:

Detection: Discovery via Domain Groups

Detection Timestamp: Feb. 19, 2025 12:51:05

Command line

C:\Windows\system32\net1 group "Domain Admins" /domain

File path

\Device\HarddiskVolume2\Windows\System32\net1.exe

Immediately following the neutralized credential theft attempts, the adversary transitioned to **Discovery**. This action represents "Target Selection" within the [] domain.

The adversary utilized the native Windows **net.exe** utility (which spawned **net1.exe**) to enumerate the **"Domain Admins"** group.

Since the local credential dumping was blocked, the attacker shifted focus to identifying high-value targets with domain-wide privileges. This information is typically used to plan **Lateral Movement** or to identify accounts for targeted exploitation

Analysis

Command Line Breakdown: Phase 1 (Defense Evasion & Security Impairment)

♦ "C:\ProgramData\Microsoft\Windows Defender\Platform\4.18.25010.11-0\MpCmdRun.exe" SignaturesUpdateService -ScheduleJob -UnmanagedUpdate

- **MpCmdRun.exe** → A legitimate Microsoft Defender binary used for **Masquerading**. By running under the guise of a signature update, the adversary attempts to blend in with standard maintenance tasks.
- **Debugger Evasion** → The process was flagged for checking the environment for analysis tools. This is a proactive defense evasion tactic to ensure the payload isn't running in a sandbox or being monitored by a debugger.
- **wevtutil.exe uninstall-manifest / install-manifest** → A sophisticated method of **Indicator Removal**. By cycling the manifests for AMFilter and RTP, the attacker effectively "blinds" specific event providers, preventing the generation of security logs that would alert analysts to the ongoing breach.

♦ **MsMpEng.exe (LSASS Handle Acquisition)**

- **Credential Access** → The antimalware service was leveraged to obtain a memory handle to LSASS. Since security tools naturally interact with system memory, the adversary uses this **Living-off-the-Land** technique to hide their attempt to scrape credentials from memory.

Command Line Breakdown: Phase 2 (Scripted Credential Dumping - Neutralized)

Command: **powershell.exe -WindowStyle Hidden -ExecutionPolicy Bypass -NonInteractive -File "C:\Windows\Temp\healthcheck.ps1"**

- ♦ **-WindowStyle Hidden** → Prevents a console window from appearing, ensuring the script runs silently in the background without alerting any logged-in administrator.
- ♦ **-ExecutionPolicy Bypass** → Bypasses local script-signing restrictions, allowing the execution of the unauthorized **healthcheck.ps1** script.
- ♦ **healthcheck.ps1** → A deceptive filename staged in a world-writable directory (**\Temp**). This script acted as the primary orchestrator for the subsequent registry attacks.

Command: **reg.exe save HKLM\SYSTEM C:\Windows\Temp\system.hive /y**

- ♦ **reg.exe save** → An attempt to perform **OS Credential Dumping**. By exporting the **SYSTEM** and **SAM** hives, the attacker intends to exfiltrate the boot key and local NTLM hashes for offline cracking.
- ♦ **The Verdict (SUCCESSFUL BLOCK)** → Telemetry confirms **PatternDisposition: 2048**. The Falcon sensor intervened at the kernel level, terminating the process before the sensitive hive data could be written to disk.

Command Line Breakdown: Phase 3 (Active Directory Reconnaissance)

Command: `net1 group "Domain Admins" /domain`

- ♦ **net1.exe** → The functional component of the `net.exe` suite. While the binary is clean (0/72 on VT), its execution context (spawned immediately after a failed credential dump) confirms malicious intent.
- ♦ **Discovery** → Targeted enumeration of the "Domain Admins" group. Having failed to steal local credentials, the adversary shifted focus to identifying high-value targets within the [redacted] domain to plan for **Lateral Movement**.
- ♦ **-aip [redacted]** → The activity is tied to this external IP, marking it as a critical Indicator of Compromise (IoC) for perimeter log correlation.

Potential Impact

Full Domain Compromise (Prevented): If the SAM/SYSTEM hive exports had succeeded, the adversary would have gained the keys to the kingdom. On a Domain Controller, this allows for the decryption of all domain account hashes, leading to total control over the [redacted-domain] infrastructure.

Privilege Escalation & Lateral Movement: The successful enumeration of the "Domain Admins" group provided the attacker with a roadmap of high-value targets. This information significantly narrows the adversary's focus for secondary attack vectors like spear-phishing or pass-the-hash.

Persistence via Task Scheduler: The execution via `svchost.exe (Schedule)` confirms the adversary successfully established **Persistence**. This ensures the malicious script remains active across reboots, providing a long-term "foothold" on the most critical server in the network.

Defense Evasion Success: The manipulation of Windows Defender manifests (`wevtutil`) and the use of debugger evasion indicates a high level of sophistication. The adversary is actively working to reduce "dwell time" visibility by impairing the system's ability to log its own compromise.

Living-off-the-Land (LotL) Efficiency: By using only native binaries (`reg.exe`, `net.exe`, `powershell.exe`, `MpCmdRun.exe`), the attacker minimized their file footprint, making it significantly harder for traditional signature-based antivirus to detect the intrusion.

Response

A thorough review of the raw telemetry via Advanced Event Search (AES) confirms that automated mitigation was successfully performed by the Falcon sensor during the critical phase of the intrusion.

Credential Dumping Blocked: For the identified `reg.exe` processes, the `PatternDispositionValue` was confirmed as `2048`. Technical validation of the flags identified `ProcessBlocked` as `true`, proving that the sensor actively terminated the execution chain before the SAM and SYSTEM hives could be written to disk.

```
PatternDispositionValue: 2048
PatternDispositionFlags.ProcessBlocked: true
PatternDispositionDescription: Prevention, process was blocked from execution
```

Process
reg.exe

Severity
Critical

Description
A process saved the Security Account Manager SAM or SYSTEM hive to disk. If this is unexpected, it likely indicates credential theft. Investigate the process tree.

Command line
"C:\Windows\system32\reg.exe" "C:\Windows\system32\reg.exe" save HKLM\SAM C:\Windows\Temp\sam.hive /y

File path
\\Device\HarddiskVolume2\Windows\System32\reg.exe

Actions taken
Process blocked

Objective
Gain Access

Tactic
Credential Access

Technique
OS Credential Dumping

In contrast, the reconnaissance activity performed by `net1.exe` (Domain Admin enumeration) resulted in no automated mitigation (**Actions taken: None**). While the activity was flagged as a suspicious "Associated Lead," the process was allowed to complete, meaning the adversary successfully obtained a list of privileged domain accounts.

Overall Analyst Assessment

An automated, multi-stage intrusion was detected on host **DC**, targeting the core identity infrastructure of the [redacted] domain. The attack utilized advanced **Living-off-the-Land (LotL)** techniques, beginning with a sophisticated effort to **Impair Defenses**. The adversary manipulated legitimate Windows Defender binaries (**MpCmdRun.exe** and **MsMpEng.exe**) to perform debugger evasion and attempt unauthorized access to LSASS memory, aiming to "blind" the defensive suite before the primary objective.

The core of the intrusion involved a high-severity attempt at **OS Credential Dumping**. Staged via a persistent **Scheduled Task**, a hidden PowerShell script (**healthcheck.ps1**) was executed from the **\Temp** directory to export the **SAM** and **SYSTEM** registry hives. Advanced telemetry from **Advanced Event Search (AES)** confirms a **successful mitigation** by the Falcon sensor: the **reg.exe** execution chain was terminated at the kernel level (**PatternDisposition: 2048**), preventing the exfiltration of domain password hashes and boot keys.

Following the blocked exfiltration, the adversary immediately shifted to **Active Directory Discovery**. Using **net1.exe**, the attacker successfully enumerated the **"Domain Admins"** group. Although this reconnaissance phase was not blocked, it highlights the adversary's intent to identify high-value targets for **Lateral Movement** or secondary exploitation after the failed credential theft.

While the most critical phase (Credential Theft) was successfully neutralized by the EDR, the host cannot be considered secure. The adversary demonstrated sophisticated anti-forensic capabilities, including the manipulation of event manifests via **wevtutil**. Given that the **Scheduled Task** and the malicious script remain on the host, and a list of privileged accounts has been successfully exfiltrated, there is a high risk of follow-up activity. The host requires immediate isolation, removal of persistence mechanisms, and a proactive audit of all "Domain Admin" accounts.

Mini Attack Visualization

[MpCmdRun.exe performs Debugger Evasion (Defense Evasion)]



[MsMpEng.exe obtains handle to LSASS process (Credential Access)]



[notepad.exe opens R.txt on Desktop (Adversary playbook/instruction reference)]



[wevtutil.exe uninstalls Defender event manifests (Indicator Removal)]



[svchost.exe triggers malicious Scheduled Task (Persistence)]



[powershell.exe executes healthcheck.ps1 with Bypass (Execution)]



[reg.exe attempts to export SAM & SYSTEM hives to \Temp\ (Credential Theft — HiveCredTheft)]



[CrowdStrike Falcon: SUCCESSFUL BLOCK (PatternDisposition: 2048) — Data exfiltration prevented]



[net1.exe queries "Domain Admins" /domain (Discovery)]



[Activity associated with external IP **[redacted]** (Domain Controller public-facing IP)]



[Host DC: PARTIALLY COMPROMISED — Credential dumping blocked; Persistence artifacts remain]

Recommended actions

1. Host Containment & Artifact Removal

- **Network Containment:** Immediately perform **Network Containment** on host **DC** via the CrowdStrike console. While the credential dump was blocked, the active discovery phase suggests the adversary is still seeking an alternative path.
- **Artifact Cleanup:** Locate and securely delete the malicious script **healthcheck.ps1** from **C:\Windows\Temp**.
- **Manual Inspection:** If **notepad.exe** was used to view **R.txt**, retrieve the file for forensic analysis to identify any targeted "hit list" or secondary commands.

2. Persistence & Defender Remediation

- **Scheduled Task Audit:** Identify and delete the specific **Scheduled Task** (triggered via **svchost.exe**) that executes the PowerShell script in the **\Temp** directory.
- **Restore Defender Integrity:** Because **wevtutil.exe** was used to uninstall antimalware manifests, perform a **System File Checker (SFC /scannow)** or a manual restoration of the **AMFilter**, **RTP**, and **NIS** event manifests to ensure security logging is no longer "muted."
- **Process Termination:** Ensure all unauthorized instances of **reg.exe** and **net1.exe** associated with this chain have been fully terminated.

3. Network & IOC Controls

- **IP Blocking:** Blacklist and monitor all traffic to/from the external agent IP **[redacted]** at the perimeter firewall and VPN gateway.
- **Hash Blocklist:** Add the SHA256 hashes for **healthcheck.ps1** (**de96a6e69944335375dc1ac238336066889d9ffc7d73628ef4fe1b1b160ab32c**) and the specific **net1.exe** parent to the global environment blocklist.
- **Custom IOAs:** Create a custom IOA rule to alert on any **reg.exe save** operations targeting the **SAM** or **SYSTEM** hives, specifically when executed from world-writable directories like **\Temp** or **\Users\Public**.

4. Credential & Identity Security

- **Domain Admin Audit:** Since the adversary successfully executed **net1 group "Domain Admins" /domain**, consider the list of privileged users **compromised**. Initiate a mandatory password reset for all accounts in the "Domain Admins" group.
- **Machine Account Review:** Audit the **DC\$** account for any other unusual activity, such as the creation of "Golden Tickets" or unauthorized Kerberos Service Principal Name (SPN) registrations.
- **Privilege Review:** Review all accounts currently logged into the DC and terminate any non-essential sessions.

5. System Hardening & Policy Enforcement

- **PowerShell Hardening:** Enforce a strict **AllSigned** execution policy via Group Policy (GPO) to prevent the execution of unsigned scripts like **healthcheck.ps1**.
- **Logging Enhancement:** Ensure **PowerShell Script Block Logging** is enabled and forwarded to your SIEM to capture the full logic of future obfuscated scripts.

- **Directory Restrictions:** Implement **AppLocker** or **Windows Defender Application Control (WDAC)** to block the execution of scripts and binaries from temporary and world-writable directories (C:\Windows\Temp, C:\Users\...\AppData\Local\Temp).

6. Escalation

- **Incident Response:** Escalate this ticket to the **Level 3 / Incident Response (IR)** team and the **Active Directory (AD) Admin team** immediately. Because the attack targeted the Domain Controller and successfully bypassed logs via manifest manipulation, a deeper forensic sweep is required to ensure no other "sleeper" persistence exists in the NTDS.dit or AD schema.